HisabPro — sécurité des comptes et révocation des sessions

Les trois fiches SEC001 à SEC003 sont exécutées dans Edge sur ordinateur et mobile avec la véritable API et PostgreSQL natif isolé. Un témoin comptable définitif de100MAD est conservé avant et après tous les parcours. Les mots de passe et jetons restent uniquement en mémoire ; les preuves enregistrent des identifiants fictifs, des rôles et des codes HTTP. Une recherche des secrets et signatures JWT est effectuée avant livraison.

Un compte principal créé dans une société B reçoit un accès invité de lecture dans A par le formulaire Utilisateurs. Il rejoint A par le sélecteur et consulte réellement le témoin au Journal2025. L'administrateur désactive ensuite son accès invité dans A. L'ancien jeton reçoit403 pour la société et son journal, le témoin n'est plus affiché après rechargement, tandis que le compte principal B reste utilisable200 et administrateur de B. Le compte n'est pas supprimé globalement.

Le changement personnel de mot de passe est testé successivement pour un administrateur et un lecteur. Un mot de passe actuel incorrect est refusé400 sans changer la session ; une confirmation différente est refusée dans le formulaire sans nouvel appel serveur. Le changement correct retourne204, efface les champs et la session locale puis demande une reconnexion. L'ancien secret et l'ancien jeton versionné sont refusés401 ; la nouvelle connexion fonctionne et conserve identifiant, société et rôle. Mon compte reste accessible au lecteur sans lui donner de droits d'écriture.

Un défaut d'interface est reproduit après révocation : le403 du calendrier laissait une promesse rejetée sans gestionnaire. Le chargement initial gère maintenant le rejet, expose le message du serveur et vide la liste des exercices indisponibles. L'interface affiche Calendrier indisponible avec une nouvelle tentative et désactive la sélection. Les réponses d'un ancien chargement ou d'un ancien jeton sont ignorées ; l'horloge et les écritures ne sont pas modifiées. Les appels explicites de mutation conservent leur rejet pour leur propre formulaire. Aucun droit serveur ni règle métier comptable n'est changé.

Les premiers échecs sont conservés : une attente de champ actif non exposé par auth/me est corrigée dans le test ; l'erreur réelle de calendrier est ensuite reproduite aux deux largeurs et corrigée. Les deux parcours finaux et16tests connexes passent. Build Vite réussi en11,46s, avec avertissements existants de bundle et d'import xlsx. Les résultats détaillés et captures sont joints.

Le suivi passe à147fiches réussies,5partielles,110nonqualifiées individuellement et10bloquées par les sources. Les70statuts fonctionnels restent inchangés. La portée technique est celle des jetons versionnés : la compatibilité des anciens jetons sans version reste documentée et une reconnexion générale doit être prévue lors de l'activation de production. Aucune recette humaine globale ou mise en production n'est validée automatiquement.

Prochaine étape : consultation seule, documents et pièces jointes entre sociétés, déconnexion et protection du dernier administrateur ; puis écritures définitives, périodes fermées et campagne comptabilité/facturation complète. Aucun PostgreSQL utilisateur utilisé. RH/paie et fiscalité déclarative restent hors périmètre.